

Security+ 2.3 · Hardware Vulnerabilities

Mestre CyberSec — PDF baseado na aula do Professor Messer · 2.3 — Hardware Vulnerabilities (6:27) · [vídeo original ↗](#) · [YouTube ↗](#)

Firmware (BIOS/UEFI: a interface hardware-SO) — comprometido é quase invisível. EOL (End of Life) = sem patch, desativar ou segmentar. Legacy device: máquina antiga com vulnerabilidade explorable. Defesa: patch firmware, replace/segmenta EOL, air gap pro crítico.

Highlights que a prova cobra

- Firmware comprometido sobrevive reinstalação do SO
- EOL = sem suporte do fabricante; segmentar/replace

Dicas de prova

- 'device cannot receive updates anymore' = EOL risk
- 'compromise persists after OS reinstall' = firmware compromise

Cenário clássico: Cenário: 'impressora de fábrica antiga não pode ter patch e é exposta na internet' = legacy/EOL device risk.

Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. Comprometer um fornecedor de software pra atingir todos os clientes dele (ex: SolarWinds):
 - A)** Ataque de cadeia de suprimentos
 - B)** Watering hole
 - C)** Insider
 - D)** Zero-day

2. Cenário corporativo (Hardware Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Firmware comprometido sobrevive reinstalação do SO'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Firmware comprometido sobrevive reinstalação do SO...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

3. Cenário corporativo (Hardware Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'EOL = sem suporte do fabricante; segmentar/replace'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: EOL = sem suporte do fabricante; segmentar/replace...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (Hardware Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: '"device cannot receive updates anymore' = EOL risk'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'device cannot receive updates anymore' = EOL risk...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Hardware Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'compromise persists after OS reinstall' = firmware compromise'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'compromise persists after OS reinstall' = firmware compromise...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Hardware Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Cenário: 'impressora de fábrica antiga não pode ter patch e é exposta na internet' = legacy/EOL device risk.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Cenário: 'impressora de fábrica antiga não pode ter patch e é exposta na in...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Hardware Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Firmware comprometido sobrevive reinstalação do SO'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Firmware comprometido sobrevive reinstalação do SO...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Hardware Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'EOL = sem suporte do fabricante; segmentar/replace'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: EOL = sem suporte do fabricante; segmentar/replace...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Hardware Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'device cannot receive updates anymore' = EOL risk'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'device cannot receive updates anymore' = EOL risk...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Hardware Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'compromise persists after OS reinstall' = firmware compromise'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'compromise persists after OS reinstall' = firmware compromise...

GABARITO COMENTADO

- 1) A — Ataque de cadeia de suprimentos.** Supply chain attack compromete um elo confiável (fornecedor) pra alcançar muitos alvos de uma vez.
- 2) A — Implementar a solução correspondente: Firmware comprometido sobrevive reinstalaç.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Hardware Vulnerabilities): Firmware comprometido sobrevive reinstalação do SO. As demais alternativas configuram violações graves de co
- 3) B — Implementar a solução correspondente: EOL = sem suporte do fabricante; segmentar.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Hardware Vulnerabilities): EOL = sem suporte do fabricante; segmentar/replace. As demais alternativas configuram violações graves de co
- 4) B — Implementar a solução correspondente: 'device cannot receive updates anymore' = .** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Hardware Vulnerabilities): 'device cannot receive updates anymore' = EOL risk. As demais alternativas configuram violações graves de co
- 5) A — Implementar a solução correspondente: 'compromise persists after OS reinstall' =.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Hardware Vulnerabilities): 'compromise persists after OS reinstall' = firmware compromise. As demais alternativas configuram violações
- 6) A — Implementar a solução correspondente: Cenário: 'impressora de fábrica antiga não.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Hardware Vulnerabilities): Cenário: 'impressora de fábrica antiga não pode ter patch e é exposta na internet' = legacy/EOL device risk.
- 7) A — Implementar a solução correspondente: Firmware comprometido sobrevive reinstalaç.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Hardware Vulnerabilities): Firmware comprometido sobrevive reinstalação do SO. As demais alternativas configuram violações graves de co
- 8) B — Implementar a solução correspondente: EOL = sem suporte do fabricante; segmentar.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Hardware Vulnerabilities): EOL = sem suporte do fabricante; segmentar/replace. As demais alternativas configuram violações graves de co
- 9) B — Implementar a solução correspondente: 'device cannot receive updates anymore' = .** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Hardware Vulnerabilities): 'device cannot receive updates anymore' = EOL risk. As demais alternativas configuram violações graves de co
- 10) D — Implementar a solução correspondente: 'compromise persists after OS reinstall' =.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Hardware Vulnerabilities): 'compromise persists after OS reinstall' = firmware compromise. As demais alternativas configuram violações

